Measuring trust in agentic systems

Requirements for a runtime trust measure, and why observation alone cannot produce one.

ABSTRACT

Behavior monitoring is now standard practice in agentic deployments, and it establishes a useful fact: what an agent did. It does not, on its own, establish the fact an enforcement decision actually requires, which is what an agent should be permitted to do next.

This note sets out the requirements for a trust measure capable of supporting that second decision at runtime. We argue that such a measure cannot be a scalar attached to an agent, because trust is a property of a relationship between two parties rather than an attribute carried by one of them. We identify five properties the measure must express, describe the enforcement decisions those properties make available, and set out the limitations and open problems of the approach, including the adversarial case.

1. Scope and terms

Three terms are used throughout in a specific sense. An **agent** is a software system that selects actions under uncertainty rather than executing a predetermined sequence, typically by invoking tools or services on behalf of a principal. **Behavior monitoring** refers to the collection and analysis of observable agent activity: tool invocations, data accessed, outputs produced, timing and sequence. **Trust** is used in the operational sense common to the computational trust literature, meaning a party's expectation that another party will act within some bound, held in conditions where that party's internal reasoning cannot be directly inspected.

This note concerns the measurement problem only. It does not address enforcement architecture, the mechanics of computing a trust value, or how such a measure maps to any particular regulatory framework. Those are separate questions and several of them are, for us, commercially sensitive.

2. What behavior monitoring establishes

Monitoring is the evidence layer, and nothing that follows is possible without it. We operate behavior monitoring as a component of our own system for exactly this reason: it is the input from which everything downstream is derived.

What monitoring reliably produces is a record. For a given agent over a given window, an operator can establish which tools were called, in what order, against which data, producing which outputs, at what rate. Where the monitoring is thorough, this record is close to complete, and it is sufficient to answer questions posed in the past tense with confidence.

The difficulty arises when the record is asked to support a decision in the present tense. An agent is about to invoke a tool. Monitoring can establish that the agent has invoked that tool eleven thousand times without incident. It cannot, by itself, establish whether this twelve-thousandth invocation should proceed, because that determination depends on factors the record does not contain: how far the current request sits from the agent's established pattern, what authority the requesting context actually confers, and what the consequence of being wrong would be.

This gap is frequently misread as a monitoring coverage problem, and addressed by collecting more signal. Additional signal improves the record. It does not convert the record into a judgment.

There is a sequencing error underneath this, and it is worth stating directly because it is close to universal. Organizations deploy an agent, begin monitoring it immediately, and look for anomalies. But an anomaly is a deviation from something, and if the something was never characterized then the monitoring produces numbers that cannot be interpreted. Drift detection without prior behavioral characterization is noise monitoring without a signal theory.

Human relationships handle this ordering instinctively. Nobody can tell whether a stranger is behaving unusually, because no range has been established for them. This is precisely why new relationships begin with low stakes and close attention, and why both are relaxed as the range is mapped. The sequence is characterize, then monitor, then interpret. Deployments that invert it are generating data they have no basis to read.

3. The limits of a per-agent score

The intuitive response is to reduce the monitoring record to a scalar: a trust score per agent, maintained continuously, compared against a threshold at decision time. This approach is attractive because it is simple to implement and simple to explain, and it performs adequately in deployments with few agents and uniform sensitivity.

It degrades in a specific and predictable way. Consider a support agent with a long record of handling refund requests, which has never accessed the billing database. The refund service has substantial grounds for confidence in this agent. The billing database has almost none, since the agent has established no record with it at all. Both facts are true simultaneously, and both are derived from the same monitoring data.

A scalar attached to the agent must resolve these into one number, and whichever way it resolves them it will be wrong for one of the two services. Raising the score to reflect the refund record extends unearned confidence to billing. Lowering it to reflect the absent billing record discards evidence the refund service has legitimately accumulated.

The reduction fails because it misplaces the quantity being measured. Trust in this operational sense is held by one party about another. It is a property of the pair, and a measure that attaches to a single system has already discarded the information that makes it actionable.

> This is not an argument that per-agent scores are useless. They are a reasonable summary statistic for reporting and triage. The argument is that they are the wrong structure for an enforcement decision, which is always made in a specific relational context.

4. Requirements for a relational trust measure

Once trust is treated as pairwise, a set of requirements follows. Each of the five below is stated as a property the measure must be capable of expressing. We make no claim that this list is exhaustive.

4.1 Directionality

The measure must distinguish the trust A holds in B from the trust B holds in A, and must permit the two to differ substantially. This is not a formal nicety. In a typical deployment an orchestrator that has supervised a model across many thousands of interactions has grounds for considerable confidence in it, while the model has accumulated no comparable basis for confidence in the orchestrator, and in most architectures has no mechanism to act on one if it had. A measure that collapses the pair into a single symmetric value cannot represent the asymmetry that is actually present.

4.2 Reference to an agent-specific baseline

Deviation is only meaningful relative to an established pattern, and the pattern differs by agent. An agent that has consistently issued on the order of forty tool calls per hour is unremarkable at forty one. An agent whose established maximum is three is substantially outside its range at nine, despite nine being the smaller absolute figure.

The measure must therefore reference a baseline derived from the agent's own observed history rather than a population threshold. This is the point at which monitoring output ceases to function as a log and begins to function as a reference distribution, and it is the main reason the monitoring layer is load-bearing rather than incidental.

Characterizing that baseline is a more demanding exercise than it first appears, and it is a different question from the one performance metrics answer. The relevant questions are distributional. What does this system's output look like across representative inputs? How much variation is normal in response to materially similar requests? Under which operating conditions does behavior approach the edges of its range, and which contexts push it outside? A system whose ordinary behavior is characterized to this level can be monitored meaningfully. A system understood only through aggregate performance figures cannot, because there is no structure against which to read the monitoring output.

The parallel to human judgment is close. Sensitivity to a colleague's behavior changing is high precisely because their range is well established, and the detection often precedes articulation: something registers as off before the observer can say what shifted. That sensitivity is a function of how richly the baseline was

learned, not of how closely the person is currently being watched.

Treating the baseline as a governed artifact rather than a byproduct of telemetry has consequences that reach into existing standards. The controls below are the ones a behavioral baseline implies, set against the clauses in the major frameworks that each one already partially anticipates. The mapping is ours; the clauses are not, and several of them turn out to assume a baseline they never require anyone to establish.

TABLE 1 · CONTROLS IMPLIED BY A BEHAVIORAL BASELINE

REQUIREMENT	CONTROL	FRAMEWORK ALIGNMENT
Behavioral profile documentation	Maintain a documented behavioral profile per production system: characteristic output patterns across use case classes, known edge case behaviors, performance bands, and qualitative descriptors that metrics do not capture.	ISO 42001 §8.4, §9.1 NIST MAP 1.6, MEASURE 2.2 EU AI Act Art. 11, Art. 13
Drift threshold definition	Define the boundaries of the expected range before deployment, in both quantitative bounds and qualitative criteria. Setting the threshold is a governance decision rather than a technical one.	ISO 42001 §9.1 NIST MEASURE 2.5 EU AI Act Art. 9.7
Continuous behavioral monitoring	Compare ongoing behavior against the profile, covering output distribution, edge case handling and qualitative consistency, rather than performance metrics alone.	ISO 42001 §9.1, §10.1 NIST MANAGE 2.4 EU AI Act Art. 9, Art. 62
Post-drift inquiry protocol	A documented process for drift events that distinguishes scope failure from model failure, since the two carry different implications for whether the relationship continues.	ISO 42001 §10.1 NIST MANAGE 3.1 EU AI Act Art. 62
Repair signal standard	A defined repair signal for drift events exceeding threshold, issued to the parties whose reliance was affected rather than only to the governance function.	ISO 42001 §10.1, §10.2 NIST MANAGE 4.1 EU AI Act Art. 62, Art. 73
Baseline versioning	A formal process for re-establishing the expected range when the system is updated, treating a model version change as an event that invalidates the prior baseline.	ISO 42001 §8.4, §10.2 NIST MANAGE 2.4 EU AI Act Art. 9, Art. 17

Two of these deserve comment because they are routinely skipped in practice.

Threshold definition is consistently delegated to whoever implements the monitoring, on the reasoning that the threshold is a tuning parameter. It is not. The threshold encodes how much deviation the organization is willing to absorb before intervening, which is a statement about risk appetite and therefore a governance decision with an owner. Delegating it to implementation means the risk appetite is set implicitly, by whoever had to pick a number to make an alert fire.

Baseline versioning is skipped more often still, and it is the one with the sharpest failure mode. A model update invalidates the behavioral characterization that preceded it. The post-update system may be better in every respect and will still produce deviation against a baseline learned from its predecessor.

Organizations that update models without re-establishing the range experience a burst of alerts that correlate with the deployment rather than with any risk, conclude the monitoring is noisy, and begin discounting it. The monitoring was correct. The reference had expired.

4.3 Asymmetric adjustment

The measure must be capable of rising and falling at different rates, and specifically of falling faster than it rises.

There is a defensible reason for this beyond intuition. A long record of compliant behavior is weak evidence about the next action, since compliance is consistent with both a well-behaved agent and a compromised one that has not yet acted. A single serious violation is strong evidence, because it is inconsistent with the well-behaved case. The appropriate update on observing the violation is therefore larger than the update on observing one more compliant action, and a measure that adjusts symmetrically will misstate the evidence in both directions.

The practical consequence of getting this wrong is that teams revert to binary controls. A measure that recovers too readily provides no durable signal after an incident. A measure that cannot recover at all is functionally a revocation with extra steps.

4.4 Attenuation across indirect relationships

Agents extend confidence to one another implicitly whenever work is delegated. A service that trusts an orchestrator inherits some basis for confidence in whatever that orchestrator calls on its behalf. This inherited confidence is real, and it is weaker than confidence established directly, and it weakens further with each additional intermediary.

A measure without attenuation propagates an initial grant across the connected estate without diminishment, which reproduces the behavior of a flat allow list under a different name. The rate of attenuation and the point at which inherited confidence should be treated as absent are implementation questions, and reasonable implementations will differ.

Human institutions have handled indirect trust for a long time, and the machinery they use is more structured than it first appears. A reference is given by a named party who stakes something on it. Its weight depends on what that party knows, how recently they knew it, and what they are exposed to if they are wrong. Multiple independent references converge on confidence faster than repeated references from one source, because the latter carries no new information. All of this transfers.

TABLE 2 · CONTROLS IMPLIED BY INDIRECT TRUST

REQUIREMENT	CONTROL	FRAMEWORK ALIGNMENT
Principal accountability mapping	Identify the human actors across development and deployment, including data curation, training and operation, and document the accountability scope of each.	ISO 42001 §6.1, §8.4 NIST GOVERN 1.2 EU AI Act Art. 9, Art. 28
Voucher competence	Establish evaluation relationships before deployment. Each voucher must hold domain-relevant expertise and a documented evaluation scope, since a reference outside its competence carries no weight.	ISO 42001 §9.2 NIST GOVERN 5.2 EU AI Act Art. 43
Endorsement accountability	Endorsing parties accept accountability for the evaluation rather than limiting liability for it, and the endorsement is revisited on material model change.	ISO 42001 §9.2, Clause 7.5 NIST GOVERN 6.1 EU AI Act Art. 40
Convergent vouching	High-consequence deployments require independent endorsements with non-overlapping evaluation scope. A single chain is insufficient regardless of the strength of its single link.	ISO 42001 §8.4 NIST MAP 1.1 EU AI Act Art. 9, Art. 43
Chain of trust documentation	A documented chain for every production system, from training data provenance through deployment context, with a named accountable party at each link.	ISO 42001 Annex A NIST MAP 1.5 EU AI Act Art. 11, Art. 25

The convergent vouching requirement is the one most often resisted, usually on cost grounds, and it is the one with the clearest justification. Independent endorsements with non-overlapping scope reduce correlated error. Three references that all derive from the same evaluation, or from evaluators who share an assumption, provide roughly the confidence of one. This is why a vendor's own assurances, however thorough, cannot substitute for an assessment with different exposure, and why a measure should weight convergent independent evidence differently from repeated evidence of the same kind.

Note also what the first row implies for the measure. If accountability maps to named parties, then attenuation is not purely a function of topological distance. A two-hop path through a party with deep domain competence and real exposure may warrant more inherited confidence than a one-hop path through a party with neither. Hop count is a useful approximation and a poor substitute for the strength of the links.

4.5 Representation of absent evidence

The measure must distinguish a party about which nothing has been observed from a party that has been observed behaving badly. Binary controls collapse both into a single denied state, and the two conditions warrant different handling. Absent evidence calls for a constrained initial envelope and deliberate evidence gathering. Adverse evidence calls for containment.

In our experience this requirement is the one most often omitted, and its omission is costly in both directions: every newly introduced system is treated as hostile, or, more commonly, absence of adverse evidence is silently read as a positive finding.

5. Decisions the measure makes available

A measure satisfying the above supports enforcement decisions that a binary control cannot express. Four are worth noting.

- **Action-scoped rather than agent-scoped authorization.** The question becomes whether this pair, for this operation, at this distance from the established baseline, clears a threshold calibrated to the consequence of the operation.
- **Isolation without suspension.** A violation can constrain a specific relationship while the agent continues operating in contexts where its record remains intact.
- **Defined handling for unknown parties.** Newly introduced systems receive a constrained envelope and an evidence-gathering period rather than a binary admit or deny.
- **Repair as a process.** A measure that falls gradually can be rebuilt gradually, through demonstrated behavior over time, rather than restored by an administrative action.

6. Deviation is not uniformly adverse

One consequence of an agent-relative baseline deserves separate treatment, because it determines whether the measure is usable in production or merely defensible in principle.

Deviation from an established range is not automatically a negative finding. In human relationships this is understood without being taught. Some drift indicates growth: a colleague handling situations with more sophistication than they did a year ago departs from their established pattern, and the departure is favorable. Some drift indicates environmental change: the same person behaving differently because the conditions around them have changed, with no alteration in their reliability. Some drift indicates an actual problem, a change in disposition or capability that bears on whether they should still be relied upon.

The ordinary human response to noticing drift is not alarm. It is curiosity. Context is sought, questions are asked, the behavioral model is updated, and the expected range is revised to accommodate growth or changed circumstances. Only drift that resists benign explanation escalates into a trust concern.

Governance frameworks presently lack this distinction and tend to treat significant deviation from baseline as an event requiring remediation. The result is two failure modes that look opposite and share a cause. Genuine drift is missed, because the baseline was characterized too loosely for the signal to separate from noise. Benign drift is over-escalated, because no mechanism exists to distinguish growth from failure. Both follow from treating deviation as a scalar quantity rather than as something requiring interpretation.

For the measure, the requirement that follows is modest to state and difficult to satisfy: it must be capable of absorbing a legitimate shift in an agent's range without recording that shift as a loss of trust. We regard the reliable separation of benign from adverse drift as the hardest open problem in this area, and we treat claims to have solved it with suspicion, including our own.

7. A note on explainability

Framing trust as relational carries an implication for explainability that is worth drawing out, because it diverges from where most current effort is directed.

The dominant explainability program aims at technical transparency: post-hoc explanations, attention maps, feature attribution, artifacts that expose why a model produced a particular output. This is valuable research. It is not, however, what an enforcement decision requires.

What governance needs is closer to what a working relationship needs, which is behavioral legibility rather than access to internals. A colleague accounts for a decision by articulating reasoning in terms commensurable with a shared understanding of the work, not by providing access to their neural activity. The account is adequate when it makes the behavior interpretable in context: whether the action fell inside the expected range, why it departed if it did, and what the departure implies for future expectations.

An explanation that satisfies those three conditions supports a trust decision even when the internal computation remains opaque. An explanation that exposes internal computation without situating the behavior against an expected range does not, which is why interpretability advances have not translated into governance confidence as directly as was anticipated.

8. Limitations and open problems

Four limitations are worth stating plainly, since each is a real cost of the approach.

Cold start. A baseline requires observation, and an agent must be permitted to act before there is anything to observe. The initial envelope is therefore a judgment informed by whatever indirect evidence exists, and it will sometimes be set too tightly, producing friction, or too loosely, producing exposure. We do not regard this as solved.

Adversarial accumulation. A measure that can be raised through behavior can be raised deliberately. An agent, or an actor controlling one, that operates patiently within its envelope while accumulating standing, and then exercises that standing once, is a coherent attack against this class of system. Mitigations exist, but any implementation that does not treat this as a design assumption is unserious.

Baseline validity under change. Discussed in section 6. Worth restating as a limitation rather than only as a design requirement: until benign and adverse drift can be separated reliably, any deployment of this approach carries a false-positive burden that has to be absorbed by human review.

Measurement cost. Maintaining pairwise state across an estate is more expensive than maintaining a scalar per agent, in storage, in computation and in explicability. Whether the additional expressiveness justifies that cost depends on the sensitivity of the deployment, and for low-consequence estates it may not.

9. Summary

Observation establishes what occurred. Enforcement requires an expectation about what will occur next, held by a specific party about a specific counterparty, informed by that counterparty's own history and by the strength of any indirect evidence standing in for direct experience.

That expectation is representable, and the requirements it must satisfy are enumerable. It is not a scalar, it is not an attribute of an agent, and it cannot be obtained by collecting more of the same signal. It is a measure over relationships, derived from observation but not reducible to it.